

PENETRATION TESTING & SECURITY ASSESSMENT REPORT

FudanSELab/train-ticket

AUTHOR	Yuval Sigura
ORIGINAL ASSESSMENT DATE	14 January 2024
ASSESSMENT TARGET	FudanSELab/train-ticket benchmark microservice system
EDITION	Public Portfolio Edition

Portfolio note: This edition preserves the findings and evidence of the original assessment while normalizing technical taxonomy and distinguishing demonstrated PoC evidence from risk analysis. No new exploitation claims are added.

1. Executive Summary

The assessment reviewed the security posture of the FudanSELab/train-ticket benchmark application across web/API behavior, authorization, authentication, input handling, security configuration, and server-side request handling. Evidence combines automated tooling, manual analysis, and selected proof-of-concept validation.

ID	Finding	Risk	OWASP 2021	Evidence
F01	Potential server-side injectio	High	A03 Injection	Time-based behavior reproduced
F02	Client-side injection / XSS ri	High	A03 Injection	Unsafe input path documented
F03	Broken access control / IDOR	High	A01 Broken Access Control	HTTP PoC documented
F04	CSRF protection disabled	High	A01 Broken Access Control	Config/source PoC
F05	Hardcoded credentials	Critical	A07 Authentication Failures	Source evidence
F06	SSRF exposure review	Risk review	A10 SSRF	Threat model + remediation
F07	Security misconfiguration	Medium	A05 Security Misconfiguration	Headers/CORS/cookies

2. Scope, Methodology & Tooling

- Web and API testing using manual exploration and Burp Suite Professional.
- Network and service reconnaissance using Nmap and Shodan.
- Static analysis / secure-code review using SonarQube and GitHub CodeQL; container review using Docker Scout.
- Manual validation of selected findings, including authorization behavior and vulnerable configuration/code paths.

Evidence boundary

The original report describes SSRF risk and prevention guidance but does not show the same direct exploit evidence as the IDOR finding. SSRF is therefore presented as an exposure review rather than a confirmed exploit.

3. Detailed Findings

F01 - Potential Server-Side Injection

High | OWASP A03:2021 - Injection

The `/api/v1/verifycode/generate` endpoint showed time-delay behavior after sleep-style input, consistent with unsafe server-side processing.

Evidence / PoC: Time-based behavior reproduced; arbitrary-code execution not independently shown.

Remediation:

- Apply strict allow-list validation, avoid dynamic evaluation of user-controlled input, use safe framework primitives, and add regression tests.

F02 - Client-Side Injection / XSS Risk

High | OWASP A03:2021 - Injection | CWE-79

The assessment documents an unsafe data path involving the `YsbCaptcha` cookie and `client_collect.js`.

Evidence / PoC: Unsafe input path documented; treated as code-path evidence rather than a fully reproduced browser exploit.

Remediation:

- Validate and contextually encode cookie values, avoid unsafe script/DOM sinks, and apply a restrictive Content Security Policy.

F03 - Broken Access Control / IDOR

High | OWASP A01:2021 - Broken Access Control

The order-service DELETE endpoint did not enforce adequate object authorization.

Evidence / PoC: Concrete GET/DELETE HTTP PoC documented in the original report.

Remediation:

- Enforce object-level authorization on every order operation, bind resources to authenticated principals, deny by default, and add negative authorization tests.

3. Detailed Findings (continued)

F04 - CSRF Protection Disabled

High | OWASP A01:2021 - Broken Access Control

Spring Security configuration explicitly disabled CSRF protection.

Evidence / PoC: Source/configuration PoC documented.

Remediation:

- Enable appropriate CSRF protections for browser-authenticated state changes; review session/authentication assumptions and HTTP methods.

F05 - Hardcoded Credentials

Critical | OWASP A07:2021 - Authentication Failures

Source evidence contained hardcoded application credentials, including a privileged administrator account.

Evidence / PoC: Source code evidence documented.

Remediation:

- Remove and rotate hardcoded credentials, use secrets management/environment configuration, enforce least privilege, and add automated secret detection.

F06 - SSRF Exposure Review

Risk Review | OWASP A10:2021 - SSRF

The assessment reviews risk from server-side URL fetching influenced by attacker-controlled input.

Evidence / PoC: Threat model and remediation only; no direct exploit request/response shown.

Remediation:

- Use positive allow-lists for schemes/hosts/ports/destinations, outbound network controls, URL normalization/validation, and monitoring.

F07 - Security Misconfiguration

Medium | OWASP A05:2021 - Security Misconfiguration

Missing security headers, permissive CORS behavior, and insecure session-cookie attributes were documented.

Evidence / PoC: Response/configuration review documented.

Remediation:

- Set appropriate security headers, restrict CORS to trusted origins, harden cookie attributes, and continuously review configuration.

4. Remediation Priorities

- Immediate: rotate hardcoded credentials; correct order-service authorization; review CSRF/session protections.
- Short term: strengthen input validation; restrict CORS; add security headers; harden cookies; apply SSRF destination controls.
- Engineering: retain SAST/container scanning, retest remediated findings manually, and track owners/due dates/retest evidence.